

Understanding the Windows SMM Security Mitigation Table (WSMT)

02/08/2023

The Windows SMM Security Mitigation Table (WSMT) is an ACPI table defined by Microsoft that allows system firmware to confirm to the operating system that certain security best practices have been implemented in System Management Mode (SMM) software. The WSMT table definition is described in the [Windows SMM Security Mitigations Table \(WSMT\) specification](#).

Background

The WSMT was defined to better support Windows Virtualization-based Security features. Please refer to [Virtualization-based Security \(VBS\)](#) for more background on VBS. Because SMM operates without the operating system's knowledge or control, SMM represents a significant attack surface that could be leveraged by malicious code to compromise or circumvent the OS protections enabled through VBS. Delivering a robust and secure VBS platform requires careful scrutiny and likely updates of SMM code by the OEM to eliminate common vulnerabilities that may be exploited. The WSMT contains flags which firmware can set to indicate to the operating system which of these specific security best practices have been implemented.

Implications of the WSMT on Windows VBS Support

The WSMT Protection Flags field indicates the presence of these specific SMM security mitigations in the systems firmware. Supported versions of the Windows operating system read the WSMT Protection Flags early during initialization, prior to hypervisor and VBS launch, and may elect to enable, disable, or de-feature certain security features based on the presence of these SMM Protections Flags.

Implementation Notes

Proper implementation of the security mitigations represented by the WSMT Protection Flags `FIXED_COMM_BUFFERS` and `COMM_BUFFER_NESTED_PTR_PROTECTION` will require the firmware vendor carefully evaluate and possibly re-design the System Management Interrupt (SMI) handlers. All SMI handlers must be restricted to only access (read or write) to allowable memory regions that contain MMIO and EFI-allocated memory. It is not sufficient to check that pointers in

SMM do not reference memory entirely outside of SMM. Rather, all SMM pointers must be validated to be within these safe memory regions. This prevents SMM from being exploited in a "confused deputy" attack, which could then be leveraged to compromise Windows VBS features. The above-mentioned Protection Flags refer only to input validation and pointer checks and do NOT currently require enforcement via SMM page protections. For example, SMM should not read or write to memory that was described by the firmware as EfiConventionalMemory because it may contain secrets or cause software to behave unpredictably.

Validating the WSMT Protections

Because SMM is opaque to the operating system, it is not possible to produce a test which runs in Windows to verify that the protections prescribed in the WSMT specification are actually implemented in SMM. From the operating system, the only check that is possible is to look for the presence of the WSMT, and check the state of all defined Protection Flags.

Therefore, it is the responsibility of the OEM to carefully scrutinize each system's SMM code and ensure that firmware complies with the guidance outlined in the WSMT specification and this article. No Protection Flag should be set to "true" until the OEM has confirmed that the mitigations corresponding to each Protection Flag value have been properly implemented. Failing to adhere to this as a best practice will leave the platform vulnerable to compromise, and negate the effectiveness of multiple OS protections and Windows security features which rely on VBS to maintain robust security boundaries.

Supported versions of Windows

Support for the WSMT is included in the following versions of Windows:

- Windows Server Technical Preview 2016
- Windows 10, version 1607
- Windows 10, version 1703
- Windows 10, version 1709